

Computer security

Computer security (also cybersecurity, digital security, or information technology (IT) security) is a subdiscipline within the field of information security. It focuses on protecting computer software, systems, and networks from threats that can lead to unauthorized information disclosure, theft, or damage to hardware, software, or data, as well as to the disruption or misdirection of the services they provide.

The growing significance of computer security reflects the increasing dependence on computer systems, the Internet, and evolving wireless network standards. This reliance has expanded with the proliferation of smart devices, including smartphones, televisions, and other components of the Internet of things (IoT).

As digital infrastructure becomes more embedded in everyday life, cybersecurity has emerged as a critical concern. The complexity of modern information systems—and the societal functions they underpin—has introduced new vulnerabilities. Systems that manage essential services, such as power grids, electoral processes, and finance, are particularly sensitive to security breaches.

Although many aspects of computer security involve digital security, such as electronic passwords and encryption, physical security measures, such as metal locks, are still used to prevent unauthorized tampering. IT security is not a perfect subset of information security and therefore does not completely align with the security convergence schema.

== Vulnerabilities and attacks ==

A vulnerability refers to a flaw in the structure, execution, functioning, or internal oversight of a computer or system that compromises its security. Most of the vulnerabilities that have been discovered are documented in the Common Vulnerabilities and Exposures (CVE) database. An exploitable vulnerability is one for which at least one working exploit exists. Actors maliciously seeking vulnerabilities are known as threats. Vulnerabilities can be researched, reverse-engineered, hunted, or exploited using automated tools or customized scripts.

Various people or parties are vulnerable to cyberattacks; however, different groups are likely to experience different types of attacks more than others.

In April 2023, the United Kingdom Department for Science, Innovation & Technology released a report on cyberattacks over the previous 12 months. They surveyed 2,263 UK businesses, 1,174 UK registered charities, and 554 education institutions. The research found that "32% of businesses and 24% of charities overall recall any breaches or attacks from the last 12 months." These figures were much higher for "medium businesses (59%), large businesses (69%), and high-income charities with £500,000 or more in annual income (56%)." Yet, although medium or large businesses are more often the victims, since larger companies have generally improved their security over the last decade, small and midsize businesses (SMBs) have also become increasingly vulnerable as they often "do not have advanced tools to defend the business." SMBs are most likely to be affected by malware, ransomware, phishing, man-in-the-middle attacks, and Denial-of Service (DoS) Attacks.

Normal internet users are most likely to be affected by untargeted cyberattacks. These are where attackers indiscriminately target as many devices, services, or users as possible. They do this using techniques that take advantage of the openness of the Internet. These strategies mostly include phishing, ransomware, water holing and scanning.

To secure a computer system, it is important to understand the attacks that can be made against it, and these threats can typically be classified into one of the following categories:

A backdoor in a computer system, a cryptosystem or an algorithm, is any secret method of bypassing normal authentication or security controls. These weaknesses may exist for many reasons, including original design or poor configuration. Due to the nature of backdoors, they are of greater concern to companies and databases as opposed to individuals.

Backdoors may be added by an authorized party to allow some legitimate access or by an attacker for malicious reasons. Criminals often use malware to install backdoors, giving them remote administrative access to a system. Once they have access, cybercriminals can "modify files, steal personal information, install unwanted software, and even take control of the entire computer."

Backdoors can be difficult to detect, as they often remain hidden within source code or system firmware and may require intimate knowledge of the operating system to identify.

=== Denial-of-service attack ===

Denial-of-service attacks (DoS) are designed to make a machine or network resource unavailable to its intended users. Attackers can deny service to individual victims, such as by deliberately entering an incorrect password enough consecutive times to cause the victim's account to be locked, or they may overload the capabilities of a machine or network and block all users at once. While a network attack from a single IP address can be blocked by adding a new firewall rule, many forms of distributed denial-of-service (DDoS) attacks are possible, where the attack comes from a large number of points. In this case, defending against these attacks is much more difficult. Such attacks can originate from the zombie computers of a botnet or from a range of other possible techniques, including distributed reflective denial-of-service (DRDoS), where innocent systems are fooled into sending traffic to the victim. With such attacks, the amplification factor makes the attack easier for the attacker because they have to use little bandwidth themselves. To understand why attackers may carry out these attacks, see the 'attacker motivation' section.

=== Physical access attacks ===

A direct-access attack is when an unauthorized user (an attacker) gains physical access to a computer, typically to copy data from it or steal information. Attackers may also compromise security by making operating system modifications, installing software worms, keyloggers, covert listening devices or using wireless microphones. Even when the system is protected by standard security measures, these may be bypassed by booting another operating system or tool from a CD-ROM or other bootable media. Disk encryption and the Trusted Platform Module standard are designed to prevent these attacks.

Direct service attackers are related in concept to direct memory attacks which allow an attacker to gain direct access to a computer's memory. The attacks "take advantage of a feature of modern computers that allows certain devices, such as external hard drives, graphics cards, or network cards, to access the computer's memory directly."

=== Eavesdropping ===

Eavesdropping is the act of surreptitiously listening to a private computer conversation (communication), usually between hosts on a network. It typically occurs when a user connects to a network where traffic is not secured or encrypted and sends sensitive business data to a colleague, which, when listened to by an attacker, could be exploited. Data transmitted across an open network can be intercepted by an attacker using various methods.

Unlike malware, direct-access attacks, or other forms of cyberattacks, eavesdropping attacks are unlikely to negatively affect the performance of networks or devices, making them difficult to notice. In fact, "the attacker does not need to have any ongoing connection to the software at all. The attacker can insert the software onto a compromised device, perhaps by direct insertion or perhaps by a virus or other malware, and then come back some time later to retrieve any data that is found or trigger the software to send the data at some determined time."

Using a virtual private network (VPN), which encrypts data between two points, is one of the most common forms of protection against eavesdropping. Using the best form of encryption possible for wireless networks is best practice, as well as using HTTPS instead of an unencrypted HTTP.

Programs such as Carnivore and NarusInSight have been used by the Federal Bureau of Investigation (FBI) and the NSA to eavesdrop on the systems of internet service providers. Even machines that operate as a closed system (i.e., with no contact with the outside world) can be

eavesdropped upon by monitoring the faint electromagnetic transmissions generated by the hardware. TEMPEST is a specification by the NSA referring to these attacks.

Malicious software (malware) is any software code or computer program "intentionally written to harm a computer system or its users." Once present on a computer, it can leak sensitive details such as personal information, business information and passwords, can give control of the system to the attacker, and can corrupt or delete data permanently.

==== Types of malware ====

Viruses are a specific type of malware, and are normally a malicious code that hijacks software with the intention to "do damage and spread copies of itself." Copies are made with the aim of spreading to other programs on a computer.

Worms are similar to viruses, however viruses can only function when a user runs (opens) a compromised program. Worms are self-replicating malware that spread between programs, apps and devices without the need for human interaction.

Trojan horses are programs that pretend to be helpful or hide themselves within desired or legitimate software to "trick users into installing them." Once installed, a RAT (Remote Access Trojan) can create a secret backdoor on the affected device to cause damage.

Spyware is a type of malware that secretly gathers information from an infected computer and transmits the sensitive information back to the attacker. One of the most common forms of spyware is keyloggers, which record all of a user's keyboard inputs/keystrokes, to "allow hackers to harvest usernames, passwords, bank account and credit card numbers."

Scareware, as the name suggests, is a form of malware that uses social engineering (manipulation) to scare, shock, trigger anxiety, or suggest the perception of a threat in order to manipulate users into buying or installing unwanted software. These attacks often begin with a "sudden pop-up with an urgent message, usually warning the user that they've broken the law or their device has a virus."

Ransomware is when malware installs itself onto a victim's machine, encrypts their files, and then turns around and demands a ransom (usually in Bitcoin) to return that data to the user.

=== Man-in-the-middle attacks ===

Man-in-the-middle attacks (MITM) involve a malicious attacker trying to intercept, surveil or modify communications between two parties by spoofing one or both party's identities and injecting themselves in-between. Types of MITM attacks include:

IP address spoofing is where the attacker hijacks routing protocols to reroute the targets traffic to a vulnerable network node for traffic interception or injection.

Message spoofing (via email, SMS or OTT messaging) is where the attacker spoofs the identity or carrier service while the target is using messaging protocols like email, SMS or OTT (IP-based) messaging apps. The attacker can then monitor conversations, launch social attacks or trigger zero-day-vulnerabilities to allow for further attacks.

WiFi SSID spoofing is where the attacker simulates a Wi-Fi base station SSID to capture and modify internet traffic and transactions. The attacker can also use local network addressing and reduced network defenses to penetrate the target's firewall by breaching known vulnerabilities. Sometimes known as a Pineapple attack thanks to a popular device. See also Malicious association.

DNS spoofing is where attackers hijack domain name assignments to redirect traffic to systems under the attackers' control, in order to surveil traffic or launch other attacks.

SSL hijacking, typically coupled with another media-level MITM attack, is where the attacker spoofs the SSL authentication and encryption protocol by way of Certificate Authority injection in order to decrypt, surveil and modify traffic. See also TLS interception

=== Multi-vector, polymorphic attacks ===

Surfacing in 2017, a new class of multi-vector, polymorphic cyber threats combine several types of attacks and change form to avoid cybersecurity controls as they spread.

Multi-vector polymorphic attacks, as the name describes, are both multi-vector and polymorphic. Firstly, they are a singular attack that involves multiple methods of attack. In this sense, they are "multi-vector" (i.e. the attack can use multiple means of propagation such as via the Web, email and applications). However, they are also multi-staged, meaning that "they can infiltrate networks and move laterally inside the network." The attacks can be polymorphic, meaning that the cyberattacks used such as viruses, worms or trojans "constantly change ("morph") making it nearly impossible to detect them using signature-based defences."

Phishing is the attempt to acquire sensitive information such as usernames, passwords, and credit card details directly from users by deceiving the users. Phishing is typically carried out by email spoofing, instant messaging, text message, or on a phone call. They often direct users to enter details at a fake website whose look and feel are almost identical to the legitimate one. The fake website often asks for personal information, such as login details and passwords. This information can then be used to gain access to the individual's real account on the real website.

Preying on a victim's trust, phishing can be classified as a form of social engineering. Attackers can use creative ways to gain access to real accounts. A common scam is for attackers to send fake electronic invoices to individuals showing that they recently purchased music, apps, or others, and instructing them to click on a link if the purchases were not authorized. A more strategic type of phishing is spear-phishing which leverages personal or organization-specific details to make the attacker appear like a trusted source. Spear-phishing attacks target specific individuals, rather than the broad net cast by phishing attempts.

=== Privilege escalation ===

Privilege escalation describes a situation where an attacker with limited access is able, without authorization, to elevate their privileges or access level. For example, a standard computer user may be able to exploit a vulnerability in the system to gain access to restricted data; or even become root and have full unrestricted access to a system. The severity of attacks can range from attacks simply sending an unsolicited email to a ransomware attack on large amounts of data. Privilege escalation usually starts with social engineering techniques, often phishing.

Privilege escalation can be separated into two strategies, horizontal and vertical privilege escalation:

Horizontal escalation (or account takeover) is where an attacker gains access to a normal user account that has relatively low-level privileges. This may be through stealing the user's username and password. Once they have access, they have gained a foothold, and using this foothold the attacker then may move around the network of users at this same lower level, gaining access to information of this similar privilege.

Vertical escalation, however, targets people higher up in a company and often with more administrative power, such as an employee in IT with a higher privilege. Using this privileged account will then enable the attacker to invade other accounts.

=== Side-channel attack ===

Any computational system affects its environment in some form. This effect it has on its environment can range from electromagnetic radiation, to residual effect on RAM cells which as a consequence make a cold boot attack possible, to hardware implementation faults that allow for access or guessing of other values that normally should be inaccessible. In Side-channel attack scenarios, the attacker would gather such information about a system or network to guess its internal state and as a result access the information which is assumed by the victim to be secure. The target information in a side channel can be challenging to detect due to its low amplitude when combined with other signals.

=== Social engineering ===

Social engineering, in the context of computer security, aims to convince a user to disclose secrets such as passwords, card numbers, etc. or grant physical access by, for example, impersonating a senior executive, bank, a contractor, or a customer. This generally involves exploiting people's trust, and relying on their cognitive biases. A common scam involves emails sent to accounting and finance department personnel, impersonating their CEO and urgently requesting action. One of the main techniques of social engineering are phishing attacks.

In early 2016, the FBI reported that such business email compromise (BEC) scams had cost US businesses more than \$2 billion in about two years.

In May 2016, the Milwaukee Bucks NBA team was the victim of this type of cyber scam with a perpetrator impersonating the team's president Peter Feigin, resulting in the handover of all the team's employees' 2015 W-2 tax forms.

Spoofing is an act of pretending to be a valid entity through the falsification of data (such as an IP address or username), in order to gain access to information or resources that one is otherwise unauthorized to obtain. Spoofing is closely related to phishing. There are several types of spoofing, including:

Email spoofing is where an attacker forges the sending (From, or source) address of an email.

IP address spoofing, where an attacker alters the source IP address in a network packet to hide their identity or impersonate another computing system.

MAC spoofing, where an attacker modifies the Media Access Control (MAC) address of their network interface controller to obscure their identity, or to pose as another.

Biometric spoofing, where an attacker produces a fake biometric sample to pose as another user.

Address Resolution Protocol (ARP) spoofing, where an attacker sends spoofed address resolution protocol onto a local area network to associate their Media Access Control address with a different host's IP address. This causes data to be sent to the attacker rather than the intended host.

In 2018, the cybersecurity firm Trellix published research on the life-threatening risk of spoofing in the healthcare industry.

Tampering describes a malicious modification or alteration of data. It is an intentional but unauthorized act resulting in the modification of a system, components of systems, its intended behavior, or data. So-called Evil Maid attacks and security services planting of surveillance capability into routers are examples.

=== HTML smuggling ===

HTML smuggling allows an attacker to smuggle a malicious code inside a particular HTML or web page. HTML files can carry payloads concealed as benign, inert data in order to defeat content filters. These payloads can be reconstructed on the other side of the filter.

When a target user opens the HTML, the malicious code is activated; the web browser then decodes the script, which then unleashes the malware onto the target's device.

== Information security practices ==

Information security (InfoSec) and cybersecurity are closely related but not identical. While cybersecurity addresses external and malicious threats related to the exposure to the internet, information security also covers internal policies, roles, and controls.

Employee behavior can have a big impact on information security in organizations. Cultural concepts can help different segments of the organization work effectively or work against effectiveness toward information security within an organization. Information security culture is the "...totality of patterns of behavior in an organization that contributes to the protection of information

of all kinds."

Andersson and Reimers (2014) found that employees often do not see themselves as part of their organization's information security effort and often take actions that impede organizational changes. Indeed, the Verizon Data Breach Investigations Report 2020, which examined 3,950 security breaches, discovered 30% of cybersecurity incidents involved internal actors within a company. Research shows information security culture needs to be improved continuously. In "Information Security Culture from Analysis to Change", authors commented, "It's a never-ending process, a cycle of evaluation and change or maintenance." To manage the information security culture, five steps should be taken: pre-evaluation, strategic planning, operative planning, implementation, and post-evaluation.

Pre-evaluation: To identify the awareness of information security within employees and to analyze the current security policies.

Strategic planning: To develop an awareness program, clear targets need to be set. Assembling a team of skilled professionals is helpful to achieve it.

Operative planning: Security culture can be established based on internal communication, management buy-in, security awareness and a training program.

Implementation: Four stages should be used to implement the information security culture. They are:

Commitment of the management

Communication with organizational members

Courses for all organizational members

Commitment of the employees

Post-evaluation: To assess the success of the planning and implementation, and to identify unresolved areas of concern.

== Computer protection (countermeasures) ==

In computer security, a countermeasure is an action, device, procedure or technique that reduces a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken.

Some common countermeasures are listed in the following sections:

=== Security by design ===

Security by design, or alternately secure by design, means that the software has been designed from the ground up to be secure. In this case, security is considered a main feature.

The UK government's National Cyber Security Centre separates secure cyber design principles into five sections:

Before a secure system is created or updated, companies should ensure they understand the fundamentals and the context around the system they are trying to create and identify any weaknesses in the system.

Companies should design and centre their security around techniques and defences which make attacking their data or systems inherently more challenging for attackers.

Companies should ensure that their core services that rely on technology are protected so that the systems are essentially never down.

Although systems can be created which are safe against a multitude of attacks, that does not mean that attacks will not be attempted. Despite one's security, all companies' systems should aim to be

able to detect and spot attacks as soon as they occur to ensure the most effective response to them.

Companies should create secure systems designed so that any attack that is successful has minimal severity.

These design principles of security by design can include some of the following techniques:

The principle of least privilege, where each part of the system has only the privileges that are needed for its function. That way, even if an attacker gains access to that part, they only have limited access to the whole system.

Automated theorem proving to prove the correctness of crucial software subsystems.

Code reviews and unit testing, approaches to make modules more secure where formal correctness proofs are not possible.

Defense in depth, where the design is such that more than one subsystem needs to be violated to compromise the integrity of the system and the information it holds.

Default secure settings, and design to fail secure rather than fail insecure (see fail-safe for the equivalent in safety engineering). Ideally, a secure system should require a deliberate, conscious, knowledgeable and free decision on the part of legitimate authorities in order to make it insecure.

Audit trails track system activity so that when a security breach occurs, the mechanism and extent of the breach can be determined. Storing audit trails remotely, where they can only be appended to, can keep intruders from covering their tracks.

Full disclosure of all vulnerabilities, to ensure that the window of vulnerability is kept as short as possible when bugs are discovered.

=== Security architecture ===

Security architecture can be defined as the "practice of designing computer systems to achieve security goals." These goals have overlap with the principles of "security by design" explored above, including to "make initial compromise of the system difficult," and to "limit the impact of any compromise." In practice, the role of a security architect would be to ensure the structure of a system reinforces the security of the system, and that new changes are safe and meet the security requirements of the organization.

Similarly, Techopedia defines security architecture as "a unified security design that addresses the necessities and potential risks involved in a certain scenario or environment. It also specifies when and where to apply security controls. The design process is generally reproducible." The key attributes of security architecture are:

the relationship of different components and how they depend on each other.

determination of controls based on risk assessment, good practices, finances, and legal matters.

the standardization of controls.

Practicing security architecture provides the right foundation to systematically address business, IT and security concerns in an organization.

=== Security measures ===

A state of computer security is the conceptual ideal, attained by the use of three processes: threat prevention, detection, and response. These processes are based on various policies and system components, which include the following:

Limiting the access of individuals using user account access controls and using cryptography can protect systems files and data, respectively.

Firewalls are by far the most common prevention systems from a network security perspective as they can (if properly configured) shield access to internal network services and block certain kinds of attacks through packet filtering. Firewalls can be both hardware and software-based. Firewalls monitor and control incoming and outgoing traffic of a computer network and establish a barrier between a trusted network and an untrusted network.

Intrusion Detection System (IDS) products are designed to detect network attacks in-progress and assist in post-attack forensics, while audit trails and logs serve a similar function for individual systems.

Response is necessarily defined by the assessed security requirements of an individual system and may cover the range from simple upgrade of protections to notification of legal authorities, counter-attacks, and the like. In some special cases, the complete destruction of the compromised system is favored, as it may happen that not all the compromised resources are detected.

Cybersecurity awareness training to cope with cyber threats and attacks.

Forward web proxy solutions can prevent the client to visit malicious web pages and inspect the content before downloading to the client machines.

Today, computer security consists mainly of preventive measures, like firewalls or an exit procedure. A firewall can be defined as a way of filtering network data between a host or a network and another network, such as the Internet. They can be implemented as software running on the machine, hooking into the network stack (or, in the case of most UNIX-based operating systems such as Linux, built into the operating system kernel) to provide real-time filtering and blocking. Another implementation is a so-called physical firewall, which consists of a separate machine filtering network traffic. Firewalls are common amongst machines that are permanently connected to the Internet.

Some organizations are turning to big data platforms, such as Apache Hadoop, to extend data accessibility and machine learning to detect advanced persistent threats.

In order to ensure adequate security, the confidentiality, integrity and availability of a network, known as the CIA triad, must be protected and is considered the foundation of information security. To achieve those objectives, administrative, physical and technical security measures should be employed. The amount of security afforded to an asset can only be determined when its value is known.

=== Vulnerability management ===

Vulnerability management is the cycle of identifying, fixing or mitigating vulnerabilities, especially in software and firmware. Vulnerability management is integral to computer security and network security.

Vulnerabilities can be discovered with a vulnerability scanner, which analyzes a computer system in search of known vulnerabilities, such as open ports, insecure software configuration, and susceptibility to malware. In order for these tools to be effective, they must be kept up to date with every new update the vendor releases. Typically, these updates will scan for the new vulnerabilities that were introduced recently.

Beyond vulnerability scanning, many organizations contract outside security auditors to run regular penetration tests against their systems to identify vulnerabilities. In some sectors, this is a contractual requirement.

=== Reducing vulnerabilities ===

The act of assessing and reducing vulnerabilities to cyberattacks is commonly referred to as information technology security assessments. They aim to assess systems for risk and to predict and test for their vulnerabilities. While formal verification of the correctness of computer systems is possible, it is not yet common. Operating systems formally verified include seL4, and SYSGO's PikeOS – but these make up a very small percentage of the market.

It is possible to reduce an attacker's chances by keeping systems up to date with security patches and updates and by hiring people with expertise in security. Large companies with significant threats can hire Security Operations Centre (SOC) Analysts. These are specialists in cyber defences, with their role ranging from "conducting threat analysis to investigating reports of any new issues and preparing and testing disaster recovery plans."

Whilst no measures can completely guarantee the prevention of an attack, these measures can help mitigate the damage of possible attacks. The effects of data loss/damage can be also reduced by careful backing up and insurance.

Outside of formal assessments, there are various methods of reducing vulnerabilities, including hardening systems. Two factor authentication is a method for mitigating unauthorized access to a system or sensitive information. It requires something you know: a password or PIN, and something you have: a card, dongle, cellphone, or another piece of hardware. This increases security as an unauthorized person needs both of these to gain access.

Protecting against social engineering and direct computer access (physical) attacks can only happen by non-computer means, which can be difficult to enforce, relative to the sensitivity of the information. Training is often involved to help mitigate this risk by improving people's knowledge of how to protect themselves and by increasing people's awareness of threats. However, even in highly disciplined environments (e.g., military organizations), social engineering attacks can still be difficult to foresee and prevent.

Inoculation, derived from inoculation theory, seeks to prevent social engineering and other fraudulent tricks and traps by instilling a resistance to persuasion attempts through exposure to similar or related attempts.

=== Hardware protection mechanisms ===

Hardware-based or assisted computer security also offers an alternative to software-only computer security. Using devices and methods such as dongles, trusted platform modules, intrusion-aware cases, drive locks, disabling USB ports, and mobile-enabled access may be considered more secure due to the physical access (or sophisticated backdoor access) required in order to be compromised. Each of these is covered in more detail below.

USB dongles are typically used in software licensing schemes to unlock software capabilities, but they can also be seen as a way to prevent unauthorized access to a computer or other device's software. The dongle, or key, essentially creates a secure encrypted tunnel between the software application and the key. The principle is that an encryption scheme on the dongle, such as Advanced Encryption Standard (AES) provides a stronger measure of security since it is harder to hack and replicate the dongle than to simply copy the native software to another machine and use it. Another security application for dongles is to use them for accessing web-based content such as cloud software or Virtual Private Networks (VPNs). In addition, a USB dongle can be configured to lock or unlock a computer.

Trusted platform modules (TPMs) secure devices by integrating cryptographic capabilities onto access devices, through the use of microprocessors, or so-called computers-on-a-chip. TPMs used in conjunction with server-side software offer a way to detect and authenticate hardware devices, preventing unauthorized network and data access.

Computer case intrusion detection refers to a device, typically a push-button switch, which detects when a computer case is opened. The firmware or BIOS is programmed to show an alert to the operator when the computer is booted up the next time.

Drive locks are essentially software tools to encrypt hard drives, making them inaccessible to thieves. Tools exist specifically for encrypting external drives as well.

Disabling USB ports is a security option for preventing unauthorized and malicious access to an otherwise secure computer. Infected USB dongles connected to a network from a computer inside the firewall are considered by the magazine Network World as the most common hardware threat

facing computer networks.

Disconnecting or disabling peripheral devices (like camera, GPS, removable storage, etc.), that are not in use.

Mobile-enabled access devices are growing in popularity due to the ubiquitous nature of cell phones. Built-in capabilities such as Bluetooth, the newer Bluetooth low-energy (LE), near-field communication (NFC) on non-iOS devices and biometric validation such as thumbprint readers, as well as QR code reader software designed for mobile devices, offer new, secure ways for mobile phones to connect to access control systems. These control systems provide computer security and can also be used for controlling access to secure buildings.

IOMMUs allow for hardware-based sandboxing of components in mobile and desktop computers by utilizing direct memory access protections.

Physical Unclonable Functions (PUFs) can be used as a digital fingerprint or a unique identifier to integrated circuits and hardware, providing users the ability to secure the hardware supply chains going into their systems.

=== Secure operating systems ===

One use of the term computer security refers to technology that is used to implement secure operating systems. Using secure operating systems is a good way of ensuring computer security. These are systems that have achieved certification from an external security-auditing organization, the most popular evaluations are Common Criteria (CC).

=== Secure coding ===

In software engineering, secure coding aims to guard against the accidental introduction of security vulnerabilities. It is also possible to create software designed from the ground up to be secure. Such systems are secure by design. Beyond this, formal verification aims to prove the correctness of the algorithms underlying a system;

important for cryptographic protocols for example.

=== Capabilities and access control lists ===

Within computer systems, two of the main security models capable of enforcing privilege separation are access control lists (ACLs) and role-based access control (RBAC).

An access-control list (ACL), with respect to a computer file system, is a list of permissions associated with an object. An ACL specifies which users or system processes are granted access to objects, as well as what operations are allowed on given objects.

Role-based access control is an approach to restricting system access to authorized users, used by the majority of enterprises with more than 500 employees, and can implement mandatory access control (MAC) or discretionary access control (DAC).

A further approach, capability-based security has been mostly restricted to research operating systems. Capabilities can, however, also be implemented at the language level, leading to a style of programming that is essentially a refinement of standard object-oriented design. An open-source project in the area is the E language.

=== User security training ===

The end-user is widely recognized as the weakest link in the security chain and it is estimated that more than 90% of security incidents and breaches involve some kind of human error. Among the most commonly recorded forms of errors and misjudgment are poor password management, sending emails containing sensitive data and attachments to the wrong recipient, the inability to recognize misleading URLs and to identify fake websites and dangerous email attachments. A common mistake that users make is saving their user id/password in their browsers to make it easier to log in to banking sites. This is a gift to attackers who have obtained access to a machine

by some means. The risk may be mitigated by the use of two-factor authentication.

As the human component of cyber risk is particularly relevant in determining the global cyber risk an organization is facing, security awareness training, at all levels, not only provides formal compliance with regulatory and industry mandates but is considered essential in reducing cyber risk and protecting individuals and companies from the great majority of cyber threats.

The focus on the end-user represents a profound cultural change for many security practitioners, who have traditionally approached cybersecurity exclusively from a technical perspective, and moves along the lines suggested by major security centers to develop a culture of cyber awareness within the organization, recognizing that a security-aware user provides an important line of defense against cyberattacks.

=== Digital hygiene ===

Related to end-user training, digital hygiene or cyber hygiene is a fundamental principle relating to information security and, as the analogy with personal hygiene shows, is the equivalent of establishing simple routine measures to minimize the risks from cyber threats. The assumption is that good cyber hygiene practices can give networked users another layer of protection, reducing the risk that one vulnerable node will be used to either mount attacks or compromise another node or network, especially from common cyberattacks. Cyber hygiene should also not be mistaken for proactive cyber defence, a military term.

The most common acts of digital hygiene can include updating malware protection, cloud back-ups, passwords, and ensuring restricted admin rights and network firewalls. As opposed to a purely technology-based defense against threats, cyber hygiene mostly regards routine measures that are technically simple to implement and mostly dependent on discipline or education. It can be thought of as an abstract list of tips or measures that have been demonstrated as having a positive effect on personal or collective digital security. As such, these measures can be performed by laypeople, not just security experts.

Cyber hygiene relates to personal hygiene as computer viruses relate to biological viruses (or pathogens). However, while the term computer virus was coined almost simultaneously with the creation of the first working computer viruses, the term cyber hygiene is a much later invention, perhaps as late as 2000 by Internet pioneer Vint Cerf. It has since been adopted by the Congress and Senate of the United States, the FBI, EU institutions and heads of state.

=== Difficulty of responding to breaches ===

Responding to attempted security breaches is often very difficult for a variety of reasons, including:

Identifying attackers is difficult, as they may operate through proxies, temporary anonymous dial-up accounts, wireless connections, and other anonymizing procedures which make back-tracing difficult – and are often located in another jurisdiction. If they successfully breach security, they have also often gained enough administrative access to enable them to delete logs to cover their tracks.

The sheer number of attempted attacks, often by automated vulnerability scanners and computer worms, is so large that organizations cannot spend time pursuing each.

Law enforcement officers often lack the skills, interest or budget to pursue attackers. Furthermore, identifying attackers across a network may necessitate collecting logs from multiple locations within the network and across various countries, a process that can be both difficult and time-consuming.

Where an attack succeeds and a breach occurs, many jurisdictions now have in place mandatory security breach notification laws.

=== Types of security and privacy ===

== Systems at risk ==

The growth in the number of computer systems and the increasing reliance upon them by individuals, businesses, industries, and governments means that there are an increasing number of systems at risk.

=== Financial systems ===

The computer systems of financial regulators and financial institutions like the U.S. Securities and Exchange Commission, SWIFT, investment banks, and commercial banks are prominent hacking targets for cybercriminals interested in manipulating markets and making illicit gains. Websites and apps that accept or store credit card numbers, brokerage accounts, and bank account information are also prominent hacking targets, because of the potential for immediate financial gain from transferring money, making purchases, or selling the information on the black market. In-store payment systems and ATMs have also been tampered with in order to gather customer account data and PINs.

The UCLA Internet Report: Surveying the Digital Future (2000) found that the privacy of personal data created barriers to online sales and that more than nine out of 10 internet users were somewhat or very concerned about credit card security.

The most common web technologies for improving security between browsers and websites are named SSL (Secure Sockets Layer), and its successor TLS (Transport Layer Security), identity management and authentication services, and domain name services allow companies and consumers to engage in secure communications and commerce. Several versions of SSL and TLS are commonly used today in applications such as web browsing, e-mail, internet faxing, instant messaging, and VoIP (voice-over-IP). There are various interoperable implementations of these technologies, including at least one implementation that is open source. Open source allows anyone to view the application's source code, and look for and report vulnerabilities.

The credit card companies Visa and MasterCard cooperated to develop the secure EMV chip which is embedded in credit cards. Further developments include the Chip Authentication Program where banks give customers hand-held card readers to perform online secure transactions. Other developments in this arena include the development of technology such as Instant Issuance which has enabled shopping mall kiosks acting on behalf of banks to issue on-the-spot credit cards to interested customers.

=== Utilities and industrial equipment ===

Computers control functions at many utilities, including coordination of telecommunications, the power grid, nuclear power plants, and valve opening and closing in water and gas networks. The Internet is a potential attack vector for such machines if connected, but the Stuxnet worm demonstrated that even equipment controlled by computers not connected to the Internet can be vulnerable. In 2014, the Computer Emergency Readiness Team, a division of the Department of Homeland Security, investigated 79 hacking incidents at energy companies.

The aviation industry is very reliant on a series of complex systems which could be attacked. A simple power outage at one airport can cause repercussions worldwide, much of the system relies on radio transmissions which could be disrupted, and controlling aircraft over oceans is especially dangerous because radar surveillance only extends 175 to 225 miles offshore. There is also potential for attack from within an aircraft.

Implementing fixes in aerospace systems poses a unique challenge because efficient air transportation is heavily affected by weight and volume. Improving security by adding physical devices to airplanes could increase their unloaded weight, and could potentially reduce cargo or passenger capacity.

In Europe, with the (Pan-European Network Service) and NewPENS, and in the US with the NextGen program, air navigation service providers are moving to create their own dedicated networks.

Many modern passports are now biometric passports, containing an embedded microchip that stores a digitized photograph and personal information such as name, gender, and date of birth. In addition, more countries are introducing facial recognition technology to reduce identity-related fraud. The introduction of the ePassport has assisted border officials in verifying the identity of the passport holder, thus allowing for quick passenger processing. Plans are under way in the US, the UK, and Australia to introduce SmartGate kiosks with both retina and fingerprint recognition technology. The airline industry is moving from the use of traditional paper tickets towards the use of electronic tickets (e-tickets). These have been made possible by advances in online credit card transactions in partnership with the airlines. Long-distance bus companies are also switching over to e-ticketing transactions today.

The consequences of a successful attack range from loss of confidentiality to loss of system integrity, air traffic control outages, loss of aircraft, and even loss of life.

=== Consumer devices ===

Desktop computers and laptops are commonly targeted to gather passwords or financial account information or to construct a botnet to attack another target. Smartphones, tablet computers, smart watches, and other mobile devices such as quantified self devices like activity trackers have sensors such as cameras, microphones, GPS receivers, compasses, and accelerometers which could be exploited, and may collect personal information, including sensitive health information. WiFi, Bluetooth, and cell phone networks on any of these devices could be used as attack vectors, and sensors might be remotely activated after a successful breach.

The increasing number of home automation devices such as the Nest thermostat are also potential targets.

Today many healthcare providers and health insurance companies use the internet to provide enhanced products and services. Examples are the use of tele-health to potentially offer better quality and access to healthcare, or fitness trackers to lower insurance premiums. Patient records are increasingly being placed on secure in-house networks, alleviating the need for extra storage space.

=== Large corporations ===

Large corporations are common targets. In many cases attacks are aimed at financial gain through identity theft and involve data breaches. Examples include the loss of millions of clients' credit card and financial details by Home Depot, Staples, Target Corporation, and Equifax.

Medical records have been targeted in general identity theft, health insurance fraud, and impersonating patients to obtain prescription drugs for recreational purposes or resale. Although cyber threats continue to increase, 62% of all organizations did not increase security training for their business in 2015.

Not all attacks are financially motivated, however: security firm HBGary Federal had a serious series of attacks in 2011 from hacktivist group Anonymous in retaliation for the firm's CEO claiming to have infiltrated their group, and Sony Pictures was hacked in 2014 with the apparent dual motive of embarrassing the company through data leaks and crippling the company by wiping workstations and servers.

Vehicles are increasingly computerized, with engine timing, cruise control, anti-lock brakes, seat belt tensioners, door locks, airbags and advanced driver-assistance systems on many models. Additionally, connected cars may use WiFi and Bluetooth to communicate with onboard consumer devices and the cell phone network. Self-driving cars are expected to be even more complex. All of these systems carry some security risks, and such issues have gained wide attention.

Simple examples of risk include a malicious compact disc being used as an attack vector, and the car's onboard microphones being used for eavesdropping. However, if access is gained to a car's internal controller area network, the danger is much greater – and in a widely publicized 2015 test, hackers remotely carjacked a vehicle from 10 miles away and drove it into a ditch.

Manufacturers are reacting in numerous ways, with Tesla in 2016 pushing out some security fixes over the air into its cars' computer systems. In the area of autonomous vehicles, in September 2016 the United States Department of Transportation announced some initial safety standards, and called for states to come up with uniform policies.

Additionally, e-Drivers' licenses are being developed using the same technology. For example, Mexico's licensing authority (ICV) has used a smart card platform to issue the first e-Drivers' licenses to the city of Monterrey, in the state of Nuevo León.

Shipping companies have adopted RFID (Radio Frequency Identification) technology as an efficient, digitally secure, tracking device. Unlike a barcode, RFID can be read up to 20 feet away. RFID is used by FedEx and UPS.

Government and military computer systems are commonly attacked by activists and foreign powers. This includes local and regional government infrastructure such as traffic light controls, police and intelligence agency communications, personnel records, as well as student records.

=== Internet of things and physical vulnerabilities ===

The Internet of things (IoT) is the network of physical objects such as devices, vehicles, and buildings that are embedded with electronics, software, sensors, and network connectivity that enables them to collect and exchange data. Concerns have been raised that this is being developed without appropriate consideration of the security challenges involved.

While the IoT creates opportunities for more direct integration of the physical world into computer-based systems,

it also provides opportunities for misuse. In particular, as the Internet of Things spreads widely, cyberattacks are likely to become an increasingly physical (rather than simply virtual) threat. If a front door's lock is connected to the Internet, and can be locked/unlocked from a phone, then a criminal could enter the home at the press of a button from a stolen or hacked phone. People could stand to lose much more than their credit card numbers in a world controlled by IoT-enabled devices. Thieves have also used electronic means to circumvent non-Internet-connected hotel door locks.

An attack aimed at physical infrastructure or human lives is often called a cyber-kinetic attack. As IoT devices and appliances become more widespread, the prevalence and potential damage of cyber-kinetic attacks can increase substantially.

=== Medical systems ===

Medical devices have either been successfully attacked or had potentially deadly vulnerabilities demonstrated, including both in-hospital diagnostic equipment and implanted devices including pacemakers and insulin pumps. There are many reports of hospitals and hospital organizations getting hacked, including ransomware attacks, Windows XP exploits, viruses, and data breaches of sensitive data stored on hospital servers. On 28 December 2016 the US Food and Drug Administration released its recommendations for how medical device manufacturers should maintain the security of Internet-connected devices – but no structure for enforcement.

=== Energy sector ===

In distributed generation systems, the risk of a cyberattack is real, according to Daily Energy Insider. An attack could cause a loss of power in a large area for a long period of time, and such an attack could have just as severe consequences as a natural disaster. The District of Columbia is considering creating a Distributed Energy Resources (DER) Authority within the city, with the goal being for customers to have more insight into their own energy use and giving the local electric utility, Pepco, the chance to better estimate energy demand. The D.C. proposal, however, would "allow third-party vendors to create numerous points of energy distribution, which could potentially create more opportunities for cyberattackers to threaten the electric grid."

=== Telecommunications ===

Perhaps the most widely known digitally secure telecommunication device is the SIM (Subscriber Identity Module) card, a device that is embedded in most of the world's cellular devices before any service can be obtained. The SIM card is just the beginning of this digitally secure environment.

The Smart Card Web Servers draft standard (SCWS) defines the interfaces to an HTTP server in a smart card. Tests are being conducted to secure OTA ("over-the-air") payment and credit card information from and to a mobile phone.

Combination SIM/DVD devices are being developed through Smart Video Card technology which embeds a DVD-compliant optical disc into the card body of a regular SIM card.

Other telecommunication developments involving digital security include mobile signatures, which use the embedded SIM card to generate a legally binding electronic signature.

== Cost and impact of security breaches ==

Serious financial damage has been caused by security breaches, but because there is no standard model for estimating the cost of an incident, the only data available is that which is made public by the organizations involved. "Several computer security consulting firms produce estimates of total worldwide losses attributable to virus and worm attacks and to hostile digital acts in general. The 2003 loss estimates by these firms range from \$13 billion (worms and viruses only) to \$226 billion (for all forms of covert attacks). The reliability of these estimates is often challenged; the underlying methodology is basically anecdotal."

However, reasonable estimates of the financial cost of security breaches can actually help organizations make rational investment decisions. According to the classic Gordon-Loeb Model analyzing the optimal investment level in information security, one can conclude that the amount a firm spends to protect information should generally be only a small fraction of the expected loss (i.e., the expected value of the loss resulting from a cyber/information security breach).

== Attacker motivation ==

As with physical security, the motivations for breaches of computer security vary between attackers. Some are thrill-seekers or vandals, some are activists, others are criminals looking for financial gain. State-sponsored attackers are now common and well resourced but started with amateurs such as Markus Hess who hacked for the KGB, as recounted by Clifford Stoll in *The Cuckoo's Egg*.

Attackers motivations can vary for all types of attacks from pleasure to political goals. For example, hacktivists may target a company or organization that carries out activities they do not agree with. This would be to create bad publicity for the company by having its website crash.

High capability hackers, often with larger backing or state sponsorship, may attack based on the demands of their financial backers. These attacks are more likely to attempt more serious attack. An example of a more serious attack was the 2015 Ukraine power grid hack, which reportedly utilised the spear-phishing, destruction of files, and denial-of-service attacks to carry out the full attack.

Additionally, recent attacker motivations can be traced back to extremist organizations seeking to gain political advantage or disrupt social agendas. The growth of the internet, mobile technologies, and inexpensive computing devices have led to a rise in capabilities but also to the risk to environments that are deemed as vital to operations. All critical targeted environments are susceptible to compromise and this has led to a series of proactive studies on how to migrate the risk by taking into consideration motivations by these types of actors. Several stark differences exist between the hacker motivation and that of nation state actors seeking to attack based on an ideological preference.

A key aspect of threat modeling for any system is identifying the motivations behind potential attacks and the individuals or groups likely to carry them out. The level and detail of security measures will differ based on the specific system being protected. For instance, a home personal computer, a bank, and a classified military network each face distinct threats, despite using similar

underlying technologies.

== Computer security incident management ==

Computer security incident management is an organized approach to addressing and managing the aftermath of a computer security incident or compromise with the goal of preventing a breach or thwarting a cyberattack. An incident that is not identified and managed at the time of intrusion typically escalates to a more damaging event such as a data breach or system failure. The intended outcome of a computer security incident response plan is to contain the incident, limit damage and assist recovery to business as usual. Responding to compromises quickly can mitigate exploited vulnerabilities, restore services and processes and minimize losses.

Incident response planning allows an organization to establish a series of best practices to stop an intrusion before it causes damage. Typical incident response plans contain a set of written instructions that outline the organization's response to a cyberattack. Without a documented plan in place, an organization may not successfully detect an intrusion or compromise and stakeholders may not understand their roles, processes and procedures during an escalation, slowing the organization's response and resolution.

There are four key components of a computer security incident response plan:

Preparation: Preparing stakeholders on the procedures for handling computer security incidents or compromises

Detection and analysis: Identifying and investigating suspicious activity to confirm a security incident, prioritizing the response based on impact and coordinating notification of the incident

Containment, eradication and recovery: Isolating affected systems to prevent escalation and limit impact, pinpointing the genesis of the incident, removing malware, affected systems and bad actors from the environment and restoring systems and data when a threat no longer remains

Post incident activity: Post mortem analysis of the incident, its root cause and the organization's response with the intent of improving the incident response plan and future response efforts.

== Notable attacks and breaches ==

Some illustrative examples of different types of computer security breaches are given below.

=== Robert Morris and the first computer worm ===

In 1988, 60,000 computers were connected to the Internet, and most were mainframes, minicomputers and professional workstations. On 2 November 1988, many started to slow down, because they were running a malicious code that demanded processor time and that spread itself to other computers – the first internet computer worm. The software was traced back to 23-year-old Cornell University graduate student Robert Tappan Morris who said "he wanted to count how many machines were connected to the Internet".

=== Rome Laboratory ===

In 1994, over a hundred intrusions were made by unidentified crackers into the Rome Laboratory, the US Air Force's main command and research facility. Using trojan horses, hackers were able to obtain unrestricted access to Rome's networking systems and remove traces of their activities. The intruders were able to obtain classified files, such as air tasking order systems data and furthermore able to penetrate connected networks of National Aeronautics and Space Administration's Goddard Space Flight Center, Wright-Patterson Air Force Base, some Defense contractors, and other private sector organizations, by posing as a trusted Rome center user.

=== TJX customer credit card details ===

In early 2007, American apparel and home goods company TJX announced that it was the victim of an unauthorized computer systems intrusion and that the hackers had accessed a system that stored data on credit card, debit card, check, and merchandise return transactions.

=== Stuxnet attack ===

In 2010, the computer worm known as Stuxnet reportedly ruined almost one-fifth of Iran's nuclear centrifuges. It did so by disrupting industrial programmable logic controllers (PLCs) in a targeted attack. This is generally believed to have been launched by Israel and the United States to disrupt Iran's nuclear program – although neither has publicly admitted this.

=== Global surveillance disclosures ===

In early 2013, documents provided by Edward Snowden were published by The Washington Post and The Guardian exposing the massive scale of NSA global surveillance. There were also indications that the NSA may have inserted a backdoor in a NIST standard for encryption. This standard was later withdrawn due to widespread criticism. The NSA additionally were revealed to have tapped the links between Google's data centers.

=== Target and Home Depot breaches ===

A Ukrainian hacker known as Rescator broke into Target Corporation computers in 2013, stealing roughly 40 million credit cards, and then Home Depot computers in 2014, stealing between 53 and 56 million credit card numbers. Warnings were delivered at both corporations, but ignored; physical security breaches using self checkout machines are believed to have played a large role. "The malware utilized is absolutely unsophisticated and uninteresting," says Jim Walter, director of threat intelligence operations at security technology company McAfee – meaning that the heists could have easily been stopped by existing antivirus software had administrators responded to the warnings. The size of the thefts has resulted in major attention from state and Federal United States authorities and the investigation is ongoing.

=== Office of Personnel Management data breach ===

In April 2015, the Office of Personnel Management discovered it had been hacked more than a year earlier in a data breach, resulting in the theft of approximately 21.5 million personnel records handled by the office. The Office of Personnel Management hack has been described by federal officials as among the largest breaches of government data in the history of the United States. Data targeted in the breach included personally identifiable information such as Social Security numbers, names, dates and places of birth, addresses, and fingerprints of current and former government employees as well as anyone who had undergone a government background check. It is believed the hack was perpetrated by Chinese hackers.

=== Ashley Madison breach ===

In July 2015, a hacker group known as The Impact Team successfully breached the extramarital relationship website Ashley Madison, created by Avid Life Media. The group claimed that they had taken not only company data but user data as well. After the breach, The Impact Team dumped emails from the company's CEO, to prove their point, and threatened to dump customer data unless the website was taken down permanently. When Avid Life Media did not take the site offline the group released two more compressed files, one 9.7GB and the second 20GB. After the second data dump, Avid Life Media CEO Noel Biderman resigned; but the website remained to function.

=== Colonial Pipeline ransomware attack ===

In June 2021, the cyberattack took down the largest fuel pipeline in the U.S. and led to shortages across the East Coast.

== Legal issues and global regulation ==

International legal issues of cyberattacks are complicated in nature. There is no global base of common rules to judge, and eventually punish, cybercrimes and cybercriminals - and where security firms or agencies do locate the cybercriminal behind the creation of a particular piece of malware or form of cyberattack, often the local authorities cannot take action due to lack of laws under which to prosecute. Proving attribution for cybercrimes and cyberattacks is also a major

problem for all law enforcement agencies. "Computer viruses switch from one country to another, from one jurisdiction to another – moving around the world, using the fact that we don't have the capability to globally police operations like this. So the Internet is as if someone [had] given free plane tickets to all the online criminals of the world." The use of techniques such as dynamic DNS, fast flux and bullet proof servers add to the difficulty of investigation and enforcement.

== Role of government ==

The role of the government is to make regulations to force companies and organizations to protect their systems, infrastructure and information from any cyberattacks, but also to protect its own national infrastructure such as the national power-grid.

The government's regulatory role in cyberspace is complicated. For some, cyberspace was seen as a virtual space that was to remain free of government intervention, as can be seen in many of today's libertarian blockchain and bitcoin discussions.

Many government officials and experts think that the government should do more and that there is a crucial need for improved regulation, mainly due to the failure of the private sector to solve efficiently the cybersecurity problem. R. Clarke said during a panel discussion at the RSA Security Conference in San Francisco, he believes that the "industry only responds when you threaten regulation. If the industry doesn't respond (to the threat), you have to follow through." On the other hand, executives from the private sector agree that improvements are necessary, but think that government intervention would affect their ability to innovate efficiently. Daniel R. McCarthy analyzed this public-private partnership in cybersecurity and reflected on the role of cybersecurity in the broader constitution of political order.

On 22 May 2020, the UN Security Council held its second ever informal meeting on cybersecurity to focus on cyber challenges to international peace. According to UN Secretary-General António Guterres, new technologies are too often used to violate rights.

== International actions ==

Many different teams and organizations exist, including:

The Forum of Incident Response and Security Teams (FIRST) is the global association of CSIRTs. The US-CERT, AT&T, Apple, Cisco, McAfee, Microsoft are all members of this international team.

The Council of Europe helps protect societies worldwide from the threat of cybercrime through the Convention on Cybercrime.

The purpose of the Messaging Anti-Abuse Working Group (MAAWG) is to bring the messaging industry together to work collaboratively and to successfully address the various forms of messaging abuse, such as spam, viruses, denial-of-service attacks and other messaging exploitations. France Telecom, Facebook, AT&T, Apple, Cisco, Sprint are some of the members of the MAAWG.

ENISA : The European Network and Information Security Agency (ENISA) is an agency of the European Union with the objective to improve network and information security in the European Union.

On 14 April 2016, the European Parliament and the Council of the European Union adopted the General Data Protection Regulation (GDPR). The GDPR, which came into force on 25 May 2018, grants individuals within the European Union (EU) and the European Economic Area (EEA) the right to the protection of personal data. The regulation requires that any entity that processes personal data incorporate data protection by design and by default. It also requires that certain organizations appoint a Data Protection Officer (DPO).

The IT Security Association TeleTrust exist in Germany since June 1986, which is an international competence network for IT security.

== National actions ==

To protect national network and system security, many countries have established strategies and staffing for computer emergency response teams, proactive cyber defence, and cyber threat intelligence. National policy actions typically include cybersecurity regulations and information security standards.

Since 2010, Canada has had a cyber security strategy. This functions as a counterpart document to the National Strategy and Action Plan for Critical Infrastructure. The strategy has three main pillars: securing government systems, securing vital private cyber systems, and helping Canadians to be secure online. There is also a Cyber Incident Management Framework to provide a coordinated response in the event of a cyber incident.

The Canadian Cyber Incident Response Centre (CCIRC) is responsible for mitigating and responding to threats to Canada's critical infrastructure and cyber systems. It provides support to mitigate cyber threats, technical support to respond & recover from targeted cyber attacks, and provides online tools for members of Canada's critical infrastructure sectors. It posts regular cyber security bulletins & operates an online reporting tool where individuals and organizations can report a cyber incident.

To inform the general public on how to protect themselves online, Public Safety Canada has partnered with STOP.THINK.CONNECT, a coalition of non-profit, private sector, and government organizations, and launched the Cyber Security Cooperation Program. They also run the GetCyberSafe portal for Canadian citizens, and Cyber Security Awareness Month during October.

Public Safety Canada aims to begin an evaluation of Canada's cybersecurity strategy in early 2015.

Australian federal government announced an \$18.2 million investment to fortify the cyber security resilience of small and medium enterprises (SMEs) and enhance their capabilities in responding to cyber threats. This financial backing is an integral component of the 2023-2030 Australian Cyber Security Strategy. A substantial allocation of \$7.2 million is earmarked for the establishment of a voluntary cyber health check program, facilitating businesses in conducting a comprehensive and tailored self-assessment of their cyber security upskill.

This avant-garde health assessment serves as a diagnostic tool, enabling enterprises to ascertain the robustness of Australia's cyber security regulations. Furthermore, it affords them access to a repository of educational resources and materials, fostering the acquisition of skills necessary for an elevated cyber security posture. This groundbreaking initiative was jointly disclosed by Minister for Cyber Security Clare O'Neil and Minister for Small Business Julie Collins.

Hong Kong's Protection of Critical Infrastructures (Computer Systems) Bill (the "Bill") was passed by the Legislative Council on 19 March 2025, with the purpose to "establish legal requirements for organisations designated as critical infrastructure operators". To defend the economy and public safety against the cyber threats of severe disruption, Hong Kong's new Protection of Critical Infrastructures (Computer Systems) Ordinance (Cap.653) (Ordinance), together with its Code of Practice (CoP) guidelines for gatekeepers at the front line of defence, came into effect on 1 January 2026.

Some provisions for cybersecurity have been incorporated into rules framed under the Information Technology Act 2000.

The National Cyber Security Policy 2013 is a policy framework by the Ministry of Electronics and Information Technology (MeitY) which aims to protect the public and private infrastructure from cyberattacks, and safeguard "information, such as personal information (of web users), financial and banking information and sovereign data". CERT-In is the nodal agency which monitors the cyber threats in the country. The post of National Cyber Security Coordinator has also been created in the Prime Minister's Office (PMO).

The Indian Companies Act 2013 has also introduced cyber law and cyber security obligations on the part of Indian directors. Some provisions for cyber security have been incorporated into rules framed under the Information Technology Act 2000 Update in 2013.

Following cyberattacks in the first half of 2013, when the government, news media, television stations, and bank websites were compromised, the national government committed to the training of 5,000 new cybersecurity experts by 2017. The South Korean government blamed its northern counterpart for these attacks, as well as incidents that occurred in 2009, 2011, and 2012, but Pyongyang denies the accusations.

=== United Kingdom ===

In 2016 the National Cyber Security Centre was formed as the central body overseeing cybersecurity in the UK, as part of GCHQ. The UK government published a National Cyber Security Strategy in 2022 assigning £2.6bn for industry, skills and national security. In addition, the National Cyber Force, launched in 2020, works with GCHQ and the Ministry of Defence and aims to "transform the UK's ability to contest adversaries in cyber space, to protect the country, its people and our way of life".

=== United States ===

==== Strategies and directives =====

In 2013, executive order 13636 Improving Critical Infrastructure Cybersecurity was signed, which prompted the creation of the NIST Cybersecurity Framework.

The 2018 cyber strategy called for specific measures to harden U.S. government networks from attacks, such as the June 2015 intrusion into the U.S. Office of Personnel Management (OPM), which compromised the records of about 4.2 million current and former government employees.

In response to the Colonial Pipeline ransomware attack President Joe Biden signed Executive Order 14028 on May 12, 2021, to increase software security standards for sales to the government, tighten detection and security on existing systems, improve information sharing and training, establish a Cyber Safety Review Board, and improve incident response.

The Biden administration released a comprehensive National Cybersecurity Strategy in 2023.

===== Legislation =====

The 1986 Computer Fraud and Abuse Act prohibits unauthorized access or damage of protected computers as defined in 18 U.S.C. § 1030(e)(2).

===== Standardized government testing services =====

The General Services Administration (GSA) has standardized the penetration test service as a pre-vetted support service, to rapidly address potential vulnerabilities, and stop adversaries before they impact US federal, state and local governments. These services are commonly referred to as Highly Adaptive Cybersecurity Services (HACS).

The Department of Homeland Security has a dedicated division responsible for the response system, risk management program and requirements for cyber security in the United States called the National Cyber Security Division. The division is home to US-CERT operations and the National Cyber Alert System. The National Cybersecurity and Communications Integration Center brings together government organizations responsible for protecting computer networks and networked infrastructure.

The third priority of the FBI is to: "Protect the United States against cyber-based attacks and high-technology crimes", and they, along with the National White Collar Crime Center (NW3C), and the Bureau of Justice Assistance (BJA) are part of the multi-agency task force, The Internet Crime Complaint Center, also known as IC3.

In addition to its own specific duties, the FBI participates alongside non-profit organizations such as InfraGard.

The Computer Crime and Intellectual Property Section (CCIPS) operates in the United States Department of Justice Criminal Division. The CCIPS is in charge of investigating computer crime

and intellectual property crime and is specialized in the search and seizure of digital evidence in computers and networks. In 2017, CCIPS published A Framework for a Vulnerability Disclosure Program for Online Systems to help organizations "clearly describe authorized vulnerability disclosure and discovery conduct, thereby substantially reducing the likelihood that such described activities will result in a civil or criminal violation of law under the Computer Fraud and Abuse Act (18 U.S.C. § 1030)."

The United States Cyber Command, also known as USCYBERCOM, "has the mission to direct, synchronize, and coordinate cyberspace planning and operations to defend and advance national interests in collaboration with domestic and international partners." It has no role in the protection of civilian networks.

The U.S. Federal Communications Commission's role in cybersecurity is to strengthen the protection of critical communications infrastructure, to assist in maintaining the reliability of networks during disasters, to aid in swift recovery after, and to ensure that first responders have access to effective communications services.

The Food and Drug Administration has issued guidance for medical devices, and the National Highway Traffic Safety Administration is concerned with automotive cyber security. After being criticized by the Government Accountability Office, and following successful attacks on airports and claimed attacks on airplanes, the Federal Aviation Administration has devoted funding to securing systems on board the planes of private manufacturers, and the Aircraft Communications Addressing and Reporting System. Concerns have also been raised about the future Next Generation Air Transportation System.

The US Department of Defense (DoD) issued DoD Directive 8570 in 2004, supplemented by DoD Directive 8140, requiring all DoD employees and all DoD contract personnel involved in information assurance roles and activities to earn and maintain various industry Information Technology (IT) certifications in an effort to ensure that all DoD personnel involved in network infrastructure defense have minimum levels of IT industry recognized knowledge, skills and abilities (KSA). Andersson and Reimers (2019) report these certifications range from CompTIA's A+ and Security+ through the ICS2.org's CISSP, etc.

Computer emergency response team is a name given to expert groups that handle computer security incidents. In the US, two distinct organizations exist, although they do work closely together.

US-CERT: part of the National Cyber Security Division of the United States Department of Homeland Security.

CERT/CC: created by the Defense Advanced Research Projects Agency (DARPA) and run by the Software Engineering Institute (SEI).

In the context of U.S. nuclear power plants, the U.S. Nuclear Regulatory Commission (NRC) outlines cyber security requirements under 10 CFR Part 73, specifically in 10 CFR 73.54. The Nuclear Energy Institute's NEI 08-09 document, Cyber Security Plan for Nuclear Power Reactors, outlines a comprehensive framework for cybersecurity in the nuclear power industry.

There is growing concern that cyberspace will become the next theater of warfare. As Mark Clayton from The Christian Science Monitor wrote in a 2015 article titled "The New Cyber Arms Race":

In the future, wars will not just be fought by soldiers with guns or with planes that drop bombs. They will also be fought with the click of a mouse a half a world away that unleashes carefully weaponized computer programs that disrupt or destroy critical industries like utilities, transportation, communications, and energy. Such attacks could also disable military networks that control the movement of troops, the path of jet fighters, the command and control of warships.

This has led to new terms such as cyberwarfare and cyberterrorism. The United States Cyber Command was created in 2009 and many other countries have similar forces.

There are a few critics that question whether cyber security is as significant a threat as it is made out to be.

Cyber security is a fast-growing field of IT concerned with reducing organizations' risk of getting hacked or data breaches. According to research from the Enterprise Strategy Group, 46% of organizations say that they have a "problematic shortage" of cyber security skills in 2016, up from 28% in 2015. Commercial, government and non-governmental organizations all employ cybersecurity professionals. The fastest increases in demand for cyber security workers are in industries managing increasing volumes of consumer data such as finance, health care, and retail. However, the use of the term cybersecurity is more prevalent in government job descriptions.

Cybersecurity job titles and descriptions include:

Analyzes and assesses vulnerabilities in the infrastructure (software, hardware, networks), investigates using available tools and countermeasures to remedy the detected vulnerabilities and recommends solutions and best practices. Analyzes and assesses damage to the data/infrastructure as a result of security incidents, examines available recovery tools and processes, and recommends solutions. Tests for compliance with security policies and procedures. May assist in the creation, implementation, or management of security solutions.

Performs security monitoring, security and data/logs analysis, and forensic analysis, to detect security incidents, and mount the incident response. Investigates and utilizes new technologies and processes to enhance security capabilities and implement improvements. May also review code or perform other security engineering methodologies.

Designs a security system or major components of a security system, and may head a security design team building a new security system.

Chief Information Security Officer (CISO)

A high-level management position responsible for the entire information security division/staff. The position may include hands-on technical work.

Chief Security Officer (CSO)

A high-level management position responsible for the entire security division/staff. A newer position is now deemed needed as security risks grow.

Data Protection Officer (DPO)

A DPO is tasked with monitoring compliance with data protection laws (such as GDPR), data protection policies, awareness-raising, training, and audits.

Security consultant/specialist/intelligence

Broad titles that encompass any one or all of the other roles or titles tasked with protecting computers, networks, software, data or information systems against viruses, worms, spyware, malware, intrusion detection, unauthorized access, denial-of-service attacks, and an ever-increasing list of attacks by hackers acting as individuals or as part of organized crime or foreign governments.

Student programs are also available for people interested in beginning a career in cyber security. Meanwhile, an alternative option for information security professionals of varied experience levels to keep studying is online security training, including webcasts. A wide range of courses are also available.

In the United Kingdom, a nationwide set of cyber security forums, known as the U.K Cyber Security Forum, were established supported by the Government's cyber security strategy in order to encourage start-ups and innovation and to address the skills gap identified by the U.K Government.

In Singapore, the Cyber Security Agency has issued a Singapore Operational Technology (OT) Cybersecurity Competency Framework (OTCCF). The framework defines emerging cybersecurity

roles in Operational Technology. The OTCCF was endorsed by the Infocomm Media Development Authority (IMDA). It outlines the different OT cybersecurity job positions as well as the technical skills and core competencies necessary. It also depicts the many career paths available, including vertical and lateral advancement opportunities.

The following terms used with regards to computer security are explained below:

Access authorization restricts access to a computer to a group of users through the use of authentication systems. These systems can protect either the whole computer, such as through an interactive login screen, or individual services, such as a FTP server. There are many methods for identifying and authenticating users, such as passwords, identification cards, smart cards, and biometric systems.

Anti-virus software consists of computer programs that attempt to identify, thwart, and eliminate computer viruses and other malicious software (malware).

Applications are executable code, so general corporate practice is to restrict or block users the power to install them; to install them only when there is a demonstrated need (e.g. software needed to perform assignments); to install only those which are known to be reputable (preferably with access to the computer code used to create the application), and to reduce the attack surface by installing as few as possible. They are typically run with least privilege, with a robust process in place to identify, test and install any released security patches or updates for them.

For example, programs can be installed into an individual user's account, which limits the program's potential access, as well as being a means control which users have specific exceptions to policy. In Linux, FreeBSD, OpenBSD, and other Unix-like operating systems there is an option to further restrict an application using chroot or other means of restricting the application to its own 'sandbox'. For example. Linux provides namespaces, and Cgroups to further restrict the access of an application to system resources.

Generalized security frameworks such as SELinux or AppArmor help administrators control access.

Java and other languages which compile to Java byte code and run in the Java virtual machine can have their access to other applications controlled at the virtual machine level.

Some software can be run in software containers which can even provide their own set of system libraries, limiting the software's, or anyone controlling it, access to the server's versions of the libraries.

Authentication techniques can be used to ensure that communication end-points are who they say they are.

Automated theorem proving and other verification tools can be used to enable critical algorithms and code used in secure systems to be mathematically proven to meet their specifications.

Backups are one or more copies kept of important computer files. Typically, multiple copies will be kept at different locations so that if a copy is stolen or damaged, other copies will still exist.

Capability and access control list techniques can be used to ensure privilege separation and mandatory access control. Capabilities vs. ACLs discusses their use.

Chain of trust techniques can be used to attempt to ensure that all software loaded has been certified as authentic by the system's designers.

Confidentiality is the nondisclosure of information except to another authorized person.

Cryptographic techniques can be used to defend data in transit between systems, reducing the probability that the data exchange between systems can be intercepted or modified.

Cyber attribution, is an attribution of cybercrime, i.e., finding who perpetrated a cyberattack.

Cyberwarfare is an Internet-based conflict that involves politically motivated attacks on information and information systems. Such attacks can, for example, disable official websites and networks, disrupt or disable essential services, steal or alter classified data, and cripple financial systems.

Data integrity is the accuracy and consistency of stored data, indicated by an absence of any alteration in data between two updates of a data record.

Encryption is used to protect the confidentiality of a message. Cryptographically secure ciphers are designed to make any practical attempt of breaking them infeasible. Symmetric-key ciphers are suitable for bulk encryption using shared keys, and public-key encryption using digital certificates can provide a practical solution for the problem of securely communicating when no key is shared in advance.

Endpoint security software aids networks in preventing malware infection and data theft at network entry points made vulnerable by the prevalence of potentially infected devices such as laptops, mobile devices, and USB drives.

Firewalls serve as a gatekeeper system between networks, allowing only traffic that matches defined rules. They often include detailed logging, and may include intrusion detection and intrusion prevention features. They are near-universal between company local area networks and the Internet, but can also be used internally to impose traffic rules between networks if network segmentation is configured.

A hacker is someone who seeks to breach defenses and exploit weaknesses in a computer system or network.

Honey pots are computers that are intentionally left vulnerable to attack by crackers. They can be used to catch crackers and to identify their techniques.

Intrusion-detection systems are devices or software applications that monitor networks or systems for malicious activity or policy violations.

A microkernel is an approach to operating system design which has only the near-minimum amount of code running at the most privileged level – and runs other elements of the operating system such as device drivers, protocol stacks and file systems, in the safer, less privileged user space.

Pinging. The standard ping application can be used to test if an IP address is in use. If it is, attackers may then try a port scan to detect which services are exposed.

A port scan is used to probe an IP address for open ports to identify accessible network services and applications.

A key logger is spyware that silently captures and stores each keystroke that a user types on the computer's keyboard.

Social engineering is the use of deception to manipulate individuals to breach security.

Logic bombs is a type of malware added to a legitimate program that lies dormant until it is triggered by a specific event.

A unikernel is a computer program that runs on a minimalistic operating system where a single application is allowed to run (as opposed to a general purpose operating system where many applications can run at the same time). This approach to minimizing the attack surface is adopted mostly in cloud environments where software is deployed in virtual machines.

Zero trust security means that no one is trusted by default from inside or outside the network, and verification is required from everyone trying to gain access to resources on the network.

Since the Internet's arrival and with the digital transformation initiated in recent years, the notion of cybersecurity has become a familiar subject in both our professional and personal lives. Cybersecurity and cyber threats have been consistently present for the last 60 years of technological change. In the 1970s and 1980s, computer security was mainly limited to academia

until the conception of the Internet, where, with increased connectivity, computer viruses and network intrusions began to take off. After the spread of viruses in the 1990s, the 2000s marked the institutionalization of organized attacks such as distributed denial of service. This led to the formalization of cybersecurity as a professional discipline.

The April 1967 session organized by Willis Ware at the Spring Joint Computer Conference, and the later publication of the Ware Report, were foundational moments in the history of the field of computer security. Ware's work straddled the intersection of material, cultural, political, and social concerns.

A 1977 NIST publication introduced the CIA triad of confidentiality, integrity, and availability as a clear and simple way to describe key security goals. While still relevant, many more elaborate frameworks have since been proposed.

However, in the 1970s and 1980s, there were no grave computer threats because computers and the internet were still in the early stages of development, and security threats were easily identifiable. More often, threats came from malicious insiders who gained unauthorized access to sensitive documents and files. Although malware and network breaches existed during the early years, they did not use them for financial gain. By the second half of the 1970s, established computer firms like IBM started offering commercial access control systems and computer security software products.

One of the earliest examples of an attack on a computer network was the computer worm Creeper written by Bob Thomas at BBN, which propagated through the ARPANET in 1971. The program was purely experimental in nature and carried no malicious payload. A later program, Reaper, was created by Ray Tomlinson in 1972 and used to destroy Creeper.

Between September 1986 and June 1987, a group of German hackers performed the first documented case of cyber espionage. The group hacked into American defense contractors, universities, and military base networks and sold gathered information to the Soviet KGB. The group was led by Markus Hess, who was arrested on 29 June 1987. He was convicted of espionage (along with two co-conspirators) on 15 Feb 1990.

In 1988, one of the first computer worms, called the Morris worm, was distributed via the Internet. It gained significant mainstream media attention.

Netscape started developing the protocol SSL, shortly after the National Center for Supercomputing Applications (NCSA) launched Mosaic 1.0, the first web browser, in 1993. Netscape had SSL version 1.0 ready in 1994, but it was never released to the public due to many serious security vulnerabilities. However, in 1995, Netscape launched Version 2.0.

The National Security Agency (NSA) is responsible for the protection of U.S. information systems and also for collecting foreign intelligence. The agency analyzes commonly used software and system configurations to find security flaws, which it can use for offensive purposes against competitors of the United States.

NSA contractors created and sold click-and-shoot attack tools to US agencies and close allies, but eventually, the tools made their way to foreign adversaries. In 2016, NSA's own hacking tools were hacked, and Russia and North Korea have used it. NSA's employees and contractors have been recruited at high salaries by adversaries, anxious to compete in cyberwarfare. In 2007, the United States and Israel began exploiting security flaws in the Microsoft Windows operating system to attack and damage equipment used in Iran to refine nuclear materials. Iran responded by heavily investing in their own cyberwarfare capability, which it began using against the United States.

== Notable scholars ==

== Further reading ==

Branch, Jordan (24 September 2020). "What's in a Name? Metaphors and Cybersecurity". International Organization. 75 (1). Cambridge University Press (CUP): 39–70. doi:10.1017/s002081832000051x. ISSN 0020-8183. S2CID 224886794.

Costigan, Sean; Hennessy, Michael (2016). *Cybersecurity: A Generic Reference Curriculum* (PDF). NATO. ISBN 978-92-845-0196-0. Archived (PDF) from the original on 10 March 2017.

Fuller, Christopher J (11 June 2018). "The Roots of the United States' Cyber (In)Security" (DOC). *Diplomatic History*. 43 (1). Oxford University Press (OUP): 157–185. doi:10.1093/dh/dhy038. ISSN 0145-2096.

Bob, Yonah Jeremy (21 August 2021). "Ex-IDF cyber intel. official reveals secrets behind cyber offense". *The Jerusalem Post*.

Kim, Peter (2014). *The Hacker Playbook: Practical Guide To Penetration Testing*. Seattle: CreateSpace Independent Publishing Platform. ISBN 978-1-4949-3263-3.

Lee, Newton (2015). *Counterterrorism and Cybersecurity: Total Information Awareness* (2nd ed.). Springer. ISBN 978-3-319-17243-9.

Montagnani, Maria Lillà; Cavallo, Mirta Antonella (2018). "Cybersecurity and Liability in a Big Data World". *Market and Competition Law Review*. 2 (2). Elsevier BV: 71–98. doi:10.2139/ssrn.3220475. ISSN 1556-5068. S2CID 216704215. SSRN 3220475.

Shariati, Marzieh; Bahmani, Faezeh; Shams, Fereidoon (2011). "Enterprise information security, a review of architectures and frameworks from interoperability perspective". *Procedia Computer Science*. 3. Elsevier BV: 537–543. doi:10.1016/j.procs.2010.12.089. ISSN 1877-0509.

Singer, P. W.; Friedman, Allan (2014). *Cybersecurity and Cyberwar: What Everyone Needs to Know*. Oxford University Press. ISBN 978-0-19-991811-9.

Wu, Chwan-Hwa (John); Irwin, J. David (2013). *Introduction to Computer Networks and Cybersecurity*. Boca Raton: CRC Press. ISBN 978-1-4665-7213-3.

"Cybersecurity Best Practices". *Cybersecurity and Infrastructure Security Agency CISA*. (n.d.). Archived from the original on 25 April 2024. Retrieved 24 April 2024.

Sztyber-Betley, A., Syfert, M., Kościelny, J. M., & Górecka, Z. (2023). Controller Cyber-Attack Detection and Isolation †: Sensors (14248220). *Sensors* (14248220), 23(5), 2778. doi:10.3390/s23052778